

**UNIVERSIDAD POLITÉCNICA DE
SAN LUIS POTOSÍ**

CARRERA: Ingeniería en Tecnologías de la Información

MATERIA: CNO IV Seguridad Informática

TRABAJO: FILE PATH TRAVERSAL TRAVERSAL SEQUENCES BLOCKED
WITH ABSOLUTE PATH BYPASS

Ojeda Camacho José Carlos / 181629

PROFESOR: Servando Contreras

Contenido

Información del laboratorio	2
Objetivo del laboratorio.....	2
Explicación técnica de la vulnerabilidad	2
Procedimiento paso a paso	3
Explicación del payload	6
Mitigación recomendada.....	6

Información del laboratorio

Nombre del laboratorio: FILE PATH TRAVERSAL TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Nivel (Apprentice / Practitioner): Apprentice

Tipo de explotación: PATH TRAVERSAL

Objetivo del laboratorio

El objetivo de este laboratorio es explotar una vulnerabilidad de path traversal en la visualización de imágenes de productos donde, a pesar de bloquear secuencias de escape comunes, la aplicación interpreta el archivo proporcionado en relación con un directorio de trabajo predeterminado; para resolverlo, debes evadir esta restricción lógica y lograr extraer con éxito el contenido del archivo crítico del sistema operativo, `/etc/passwd`.

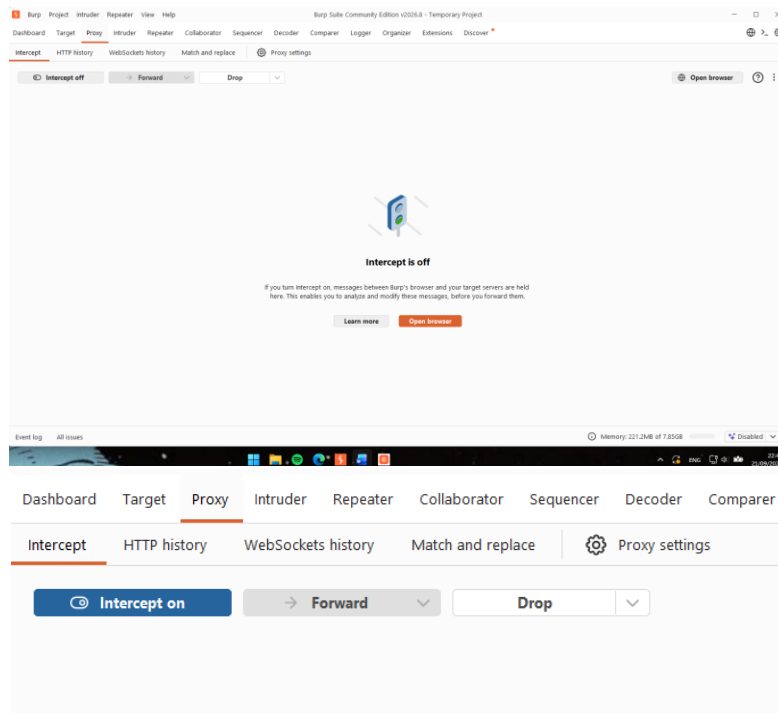
Explicación técnica de la vulnerabilidad

La vulnerabilidad radica en una deficiencia en el control de acceso y en la validación de entradas de la aplicación, la cual intenta mitigar el riesgo de *path traversal* bloqueando únicamente las secuencias relativas de navegación (como `../`); sin embargo, al no restringir el uso de rutas absolutas, el sistema procesa el parámetro de entrada de forma literal desde la raíz del servidor —ignorando el directorio de trabajo predeterminado—, lo que permite a un atacante omitir los filtros implementados y acceder de manera ilegítima a recursos críticos del sistema operativo, tales como el archivo `/etc/passwd`.

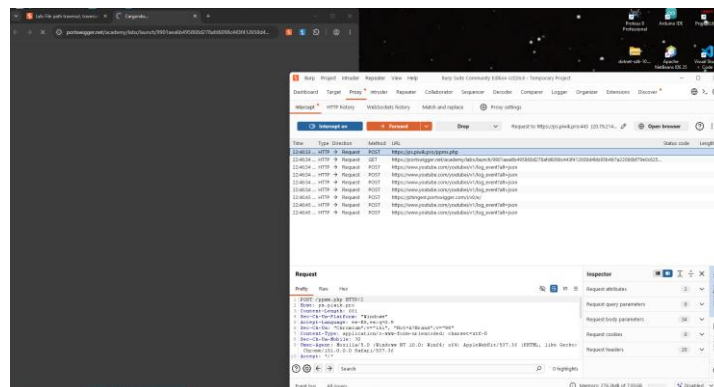
Procedimiento paso a paso

El proceso inicia con la apertura de la aplicación Burp Suite y el uso de su navegador integrado, el cual evita conflictos de configuración con certificados de seguridad.

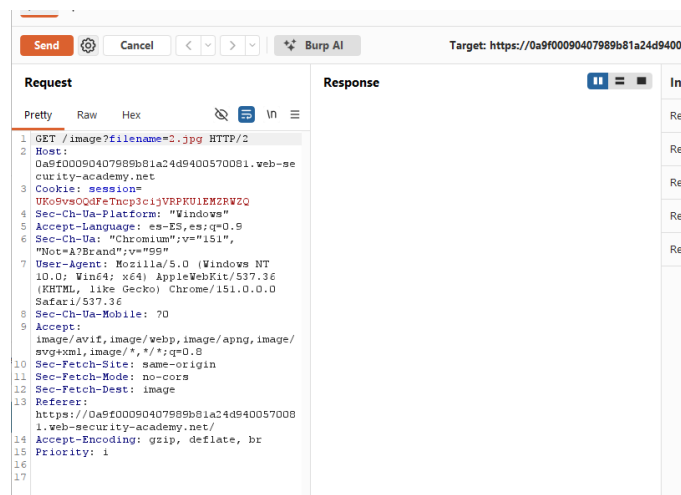
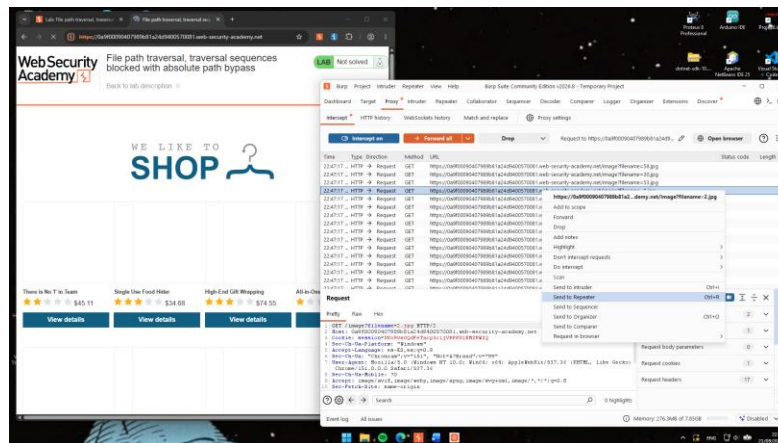
Posteriormente, en la sección **Proxy > Intercept**, se verifica que la función de intercepción se encuentre activada (**Intercept is on**). Esto permite pausar y capturar de manera temporal las peticiones HTTP generadas por el navegador antes de que alcancen el servidor de la aplicación, facilitando así su análisis y posterior modificación.



El uso del navegador integrado en Burp Suite facilita el análisis de tráfico web al enrutar las solicitudes de forma automatizada sin requerir configuraciones adicionales de certificados de seguridad. Una vez que la interceptación está activa y la petición queda retenida en el panel de control, la opción **Forward** permite liberar individualmente cada paquete HTTP retenido, enviándolo hacia su destino final en el servidor, o bien continuar el flujo normal de navegación una vez que se han realizado las inspecciones o modificaciones necesarias.



Una vez capturada la solicitud HTTP objetivo en el historial del proxy o durante la interceptación, se hace clic derecho sobre ella para desplegar el menú contextual y se selecciona la opción **Send to Repeater**. Esta acción traslada la petición a la herramienta *Repeater* de Burp Suite, la cual permite reenviar de forma manual y controlada tantas solicitudes como sea necesario, facilitando la prueba de iteraciones y modificaciones en los parámetros sin requerir una nueva interacción directa desde el navegador web.

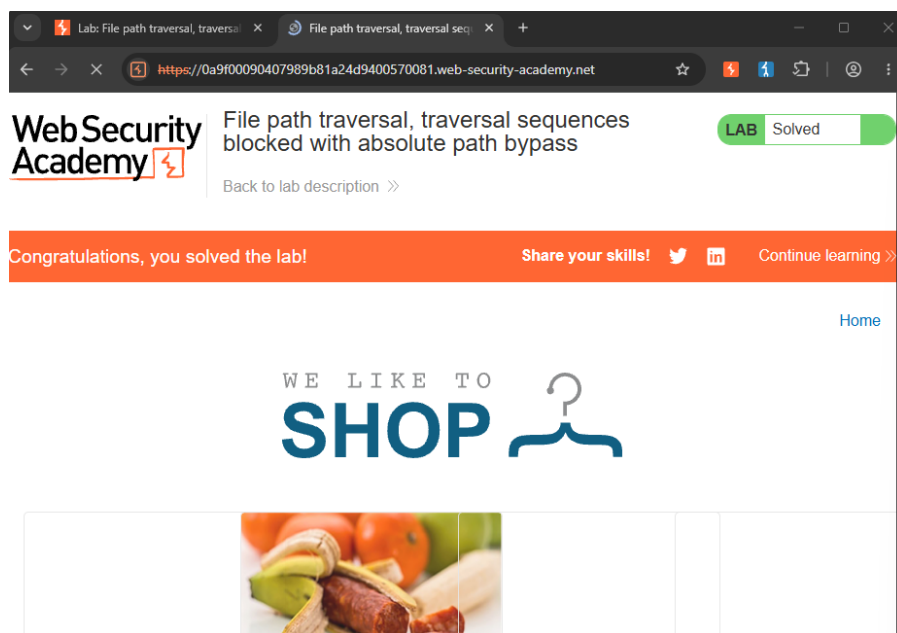


Dentro de la herramienta *Repeater*, se procede a modificar los parámetros de la petición HTTP capturada. Específicamente, en la solicitud GET /image?filename=, se reemplaza el nombre del archivo de imagen original por la ruta absoluta /etc/passwd.

El objetivo de esta inyección es aprovechar una deficiencia en la validación de las entradas del servidor. Dado que la aplicación bloquea las secuencias relativas de salto de directorio (como ../), la inyección de una ruta absoluta desde la raíz del sistema permite evadir dicho filtro. El archivo /etc/passwd es un estándar en pruebas de concepto (PoC) para vulnerabilidades de *Path Traversal* o *Local File Inclusion* (LFI), ya que es un archivo presente por defecto en sistemas basados en Unix/Linux que contiene información estructurada sobre las cuentas de usuario del sistema operativo.

Al enviar la solicitud modificada, se observa que el servidor la procesa correctamente y devuelve una respuesta con el código de estado HTTP/2 200 OK. En el cuerpo de la respuesta HTTP, el servidor expone el contenido íntegro del archivo `/etc/passwd` solicitado, mostrando claramente los registros de usuarios del sistema (tales como `root`, `daemon`, `bin`, entre otros). Esto confirma la explotación exitosa de la vulnerabilidad, demostrando que un atacante puede acceder a archivos sensibles alojados en el servidor.

Request		Response	
Pretty	Raw Hex	Pretty	Raw Hex Render
<pre>1 GET /image?filename=/etc/passwd HTTP/2 2 Host: 0a9f00090407989b81a24d9400570081.web-se curity-academy.net 3 Cookie: session= UKo9vsOQdFeTncp3ciJVVRPKULEMZRWZQ 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: es-ES,es;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/ svg+xml,image/*,*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://0a9f00090407989b81a24d940057008 1.web-security-academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: i 16 17</pre>		<pre>1 HTTP/2 200 OK 2 Content-Type: image/jpeg 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2316 5 6 root:x:0:0:root:/root:/bin/bash 7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin 8 bin:x:2:2:bin:/bin:/usr/sbin/nologin 9 sys:x:3:3:sys:/dev:/usr/sbin/nologin 10 sync:x:4:65534:sync:/bin:/bin/sync 11 games:x:5:60:games:/usr/games:/usr/sbin/nologin 12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin 13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin 14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin 15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin 16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin 17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin 18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin 19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin 20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin 21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin 22 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin 23 nobody:x:65534:65534:nobody:/nonexistent:/usr/s bin/nologin 24 _apt:x:100:65534::/nonexistent:/usr/sbin/nologi</pre>	



Explicación del payload

El *payload* utilizado en este laboratorio consiste en una ruta absoluta directa, específicamente `/etc/passwd`, la cual se introduce en el parámetro afectado sin incluir ninguna secuencia de navegación relativa (`../`). Esta estructura elude el filtro de la aplicación —el cual está diseñado únicamente para detectar y bloquear caracteres de salto de directorio—, permitiendo que la función de lectura de archivos del servidor interprete la entrada desde la raíz del sistema de archivos, ignorando el directorio de trabajo predeterminado y revelando así la información confidencial solicitada.

Mitigación recomendada

Para prevenir vulnerabilidades de *Path Traversal* como la analizada en este laboratorio, es necesario implementar un control riguroso sobre la validación y el procesamiento de las entradas del usuario. Las principales medidas de mitigación incluyen:

- **Uso de funciones de mapeo seguro (*Basename*):** Utilizar funciones integradas en el lenguaje de programación (como `basename()` en PHP) que extraigan únicamente el nombre del archivo solicitado, descartando cualquier ruta o directorio previo proporcionado en el parámetro.
- **Validación mediante listas blancas (*Whitelisting*):** Restringir los valores permitidos en los parámetros de entrada a un conjunto estricto de nombres de archivos válidos o identificadores predefinidos, rechazando cualquier cadena que contenga caracteres especiales, barras o rutas absolutas.
- **Directorio raíz confinado (*Chroot* o aislamiento):** Asegurarse de que la aplicación web se ejecute con privilegios mínimos y que el acceso a los archivos esté estrictamente limitado a un directorio específico del sistema de archivos, impidiendo que el proceso lea fuera de esa estructura autorizada.